CIA Part 1 – Final 100 Hard Questions

Foundations, Ethics, Governance/Risk/Control, Fraud (with IT and AI audit focus)

Study Deck

October 17, 2026

Format and blueprint

100 questions, one per slide; the explanation follows each question (why correct, why the others are wrong).

Aligned to the four-domain Part 1 structure: Foundations (35), Ethics and Professionalism (20), Governance, Risk Management and Control (30), Fraud Risks (15).

Terminology follows the Global Internal Audit Standards (board, CAE, advisory services, Three Lines Model).

About 17 items are technical: ITGC, SOC reports, cloud, resilience, cybersecurity, data analytics, AI governance.

Source tag in each explanation: *Orig Qn* = selected from your original files (Q1–Q400); *New* = written for this set.

Question: The CAE learns that the external auditor's plan omits a business unit that internal audit assesses as high risk. What should the CAE do?

A. Share the concern with the external auditor and cover the unit in the internal audit plan based on internal audit's own risk assessment.

B. Remove the unit from the internal audit plan to avoid duplication.

C. Instruct the external auditor to add the unit.

D. Take no action because external audit scope is not internal audit's concern.

Q1 – Explanation

Correct: A. Coordination does not make internal audit scope dependent on external audit scope. Internal audit covers the risks the organization faces.

B wrong: Assuming coverage that does not exist leaves a gap.

C wrong: Internal audit cannot direct the external auditor.

D wrong: Coordination among assurance providers is expected.

Source: New

Question: While performing an advisory engagement on a new procurement system, an auditor discovers that purchases above authority limits have routinely been approved by the CFO. This matter is outside the advisory scope. What should the auditor do?

A. Disregard it because approvals were not part of the advisory scope.

B. Add an approvals test to the advisory work and report only to the CFO.

C. Wait and address it during the next assurance engagement on procurement.

D. Communicate the matter to the CAE so it is reported to senior management and, if significant, to the board, despite being outside scope.

Q2 – Explanation

Correct: D. When significant governance, risk, or control issues are identified during advisory work, they must be communicated to senior management and the board even if outside the agreed scope.

A wrong: Scope limits do not justify silence on significant issues.

B wrong: Reporting only to the individual involved undermines independence and board oversight.

C wrong: Deferring a significant issue to a later engagement is not appropriate.

Source: New

Question: The CAE concludes that the board-approved plan cannot be completed with current staffing. Which action is MOST appropriate?

A. Quietly drop the engagements with the least management interest.

B. Ask teams to reduce testing so every engagement is completed.

C. Defer the matter until the next external quality assessment.

D. Communicate the shortfall and its impact to the board and discuss options such as risk-based prioritization, additional resources, or plan revision.

Q3 – Explanation

Correct: D. The CAE must tell the board when resource limitations will affect the ability to deliver the plan, and seek resolution.

A wrong: Dropping work without telling the board hides a scope limitation.

B wrong: Across-the-board cuts in testing may compromise the sufficiency and quality of evidence.

C wrong: An external assessment occurs on a multi-year cycle; the issue needs current communication.

Source: New

Question: During an advisory engagement on a new inventory system, management asks the auditor to decide which control design to implement. How should the auditor respond?

A. Decline, because choosing and implementing the design is a management responsibility; offer options and observations instead.

B. Choose the design, since the auditor has the most expertise.

C. Choose the design and have management approve it afterwards.

D. Choose the design but exclude the area from future assurance.

Q4 – Explanation

Correct: A. Internal auditors must not assume management responsibilities in advisory work.

B wrong: Expertise does not transfer the decision to the auditor.

C wrong: Later approval does not change who made the decision.

D wrong: Excluding future assurance does not cure the loss of objectivity.

Source: New

Question: The CAE wants to rely on the compliance function's testing of anti-bribery controls when planning assurance coverage. Which approach is MOST consistent with the Standards and the Three Lines Model?

A. Rely fully on the work because second-line functions are part of the control structure.

B. Refuse any reliance because only third-line work can be used as assurance.

C. Evaluate the compliance function's competence, objectivity, and quality of work, then decide the extent of reliance while remaining responsible for internal audit's own conclusions.

D. Rely on the work if the head of compliance confirms in writing that it was performed.

Q5 – Explanation

Correct: C. Internal audit may rely on the work of others once it has assessed its reliability, but it retains accountability for its own conclusions.

A wrong: Second-line status does not by itself establish reliability; the work must be evaluated.

B wrong: Reliance is permitted. The Standards call for coordination and reliance judgments, not a ban.

D wrong: A management assertion is not an evaluation of competence, objectivity, and quality.

Source: New

Question: A periodic self-assessment concludes that internal audit does not fully conform to the Standards because of limited technology resources. What must the CAE do?

A. Report the nonconformance, its impact, and an action plan to senior management and the board.

B. Report it only to the CFO because it concerns budget.

C. Report it only if it would change the external auditor's reliance on internal audit.

D. Defer reporting until the next external assessment confirms the result.

Q6 – Explanation

Correct: A. The CAE reports quality program results, including nonconformance and its effect on the function's scope or operations, to senior management and the board.

B wrong: Budget may be a cause, but the board must be told of the nonconformance.

C wrong: Reporting is required regardless of external auditor reliance.

D wrong: Waiting for the next external assessment delays required disclosure.

Source: New

Question: Which statement BEST distinguishes an assurance engagement from an advisory engagement?

A. Assurance may be performed only on financial processes and advisory only on operational ones.

B. Assurance typically involves three parties (process owner, internal auditor, and user of the conclusion), while advisory typically involves two.

C. Advisory engagements do not require objectivity because the client sets the scope.

D. Assurance always ends in a formal opinion on the financial statements.

Q7 – Explanation

Correct: B. Assurance gives an independent conclusion to a user other than the process owner. Advisory services are provided to the requesting client, and nature and scope are agreed with that client.

A wrong: Both types can address financial and non-financial subjects.

C wrong: Objectivity applies to all internal audit services, including advisory.

D wrong: Only external auditors opine on financial statements.

Source: New

Question: A national law prohibits internal auditors in a public body from conforming with one requirement of the Standards. What should the CAE do?

A. Disregard the law so that the function fully conforms.

B. Stop asserting any conformance with the Standards.

C. Comply with the law, conform to the remaining requirements, and disclose the nonconformance, its reason, and its impact to the board.

D. Suspend all engagements until the law is changed.

Q8 – Explanation

Correct: C. Law prevails. The CAE conforms to the extent possible and discloses the limitation and its effect.

A wrong: Violating the law is never appropriate.

B wrong: Only the affected requirement is impacted; conformance elsewhere should continue and be disclosed.

D wrong: Engagements should continue with appropriate disclosure.

Source: New

Question: The CAE should report to the board if:

A. There is a significant risk or control issue management will not address.

B. Management disagrees with a minor observation.

C. The audit budget is exceeded.

D. An auditor is late.

Q9 – Explanation

Correct: A. Significant unresolved risk/control issues must be escalated to the board.

B wrong: Minor disagreements are handled at the working level.

C wrong: Budget variances are administrative.

D wrong: Tardiness is an HR matter.

Source: Orig Q68

Question: In mid-year, a new regulation creates significant risk in a business unit that is not in the approved internal audit plan. What should the CAE do?

A. Hold the change until the annual planning cycle to preserve the approved plan.

B. Revise the plan and inform the board only in the year-end report.

C. Reassess risks, adjust the plan as needed, and communicate significant changes to senior management and the board for approval.

D. Ask management to cover the area through self-assessment.

Q10 – Explanation

Correct: C. The plan must remain risk-based and current, and significant interim changes are communicated to and approved by the board.

A wrong: The plan is dynamic; waiting leaves a significant risk uncovered.

B wrong: Significant changes require timely communication and approval, not after-the-fact disclosure.

D wrong: Self-assessment can complement but not replace independent coverage of a significant risk.

Source: New

Question: Which is an example of FUNCTIONAL reporting of the CAE to the board?

A. The CEO approves the CAE's travel and expense reports.

B. The CFO provides office space and IT support.

C. The board approves the internal audit charter and risk-based plan and evaluates the CAE's performance.

D. Human resources administers the CAE's benefits.

Q11 – Explanation

Correct: C. Functional reporting covers mandate, plan, resources, and performance oversight of the function.

A wrong: Expense approval is an administrative matter.

B wrong: Facilities and IT support are administrative.

D wrong: Benefits administration is administrative.

Source: New

Question: In a public body, legislation sets the mandate of the internal audit function. What should the CAE do regarding the charter?

A. Ignore the statute because the Standards take precedence.

B. Replace the statute's wording with the CAE's preferred scope.

C. Adopt the charter without governing body review because the law applies.

D. Ensure the charter reflects the statutory mandate and is consistent with the Standards, and have it approved by the board or equivalent governing body.

Q12 – Explanation

Correct: D. The charter documents purpose, authority, and responsibility, aligned with law and the Standards, and is approved by the governing body.

A wrong: Law must be followed; conformance is pursued within the law.

B wrong: The CAE cannot override a statutory mandate.

C wrong: Governing body approval is still expected.

Source: New

Question: Which is LEAST likely to be a valid reason for the CAE to decline an engagement?

A. The engagement would create a conflict of interest.

B. The audit team lacks the needed expertise and no specialist is available.

C. The engagement is outside the approved audit plan and unapproved.

D. The engagement would be expensive.

Q13 – Explanation

Correct: D. Cost alone is not a Standards-based reason to decline; risk, independence, objectivity, and competence are.

A wrong: Conflict of interest is a valid reason.

B wrong: Lack of competence is a valid reason.

C wrong: Out-of-plan engagements require CAE/board approval.

Source: Orig Q103

Question: Which statement BEST describes the internal audit strategy?

A. A plan of action aligned to the organization's strategy and objectives, setting out the function's vision, objectives, and supporting initiatives.

B. The list of engagements to be performed in the coming year.

C. The budget request submitted to finance.

D. The sampling methodology applied in testing.

Q14 – Explanation

Correct: A. The internal audit strategy aligns with organizational strategy and guides the audit plan and resource decisions.

B wrong: That describes the audit plan.

C wrong: The budget is one input to resources, not the strategy.

D wrong: Sampling is an engagement-level technique.

Source: New

Question: Which is the MOST appropriate response if the CAE believes the audit committee is not providing adequate oversight?

A. Document and escalate concerns appropriately (e.g., to the board).

B. Ignore it.

C. Resign immediately.

D. Report to the external auditor only.

Q15 – Explanation

Correct: A. The CAE should document and escalate governance concerns through appropriate channels.

B wrong: Ignoring governance weaknesses is improper.

C wrong: Resignation is a last resort.

D wrong: Reporting only to the external auditor is inappropriate.

Source: Orig Q140

Question: The CAE reports to the CEO administratively and to the audit committee functionally. Which statement is MOST accurate?

A. This structure supports independence while enabling administration.

B. This structure impairs independence.

C. The CAE should report only to the CEO.

D. The CAE should report only to the external auditor.

Q16 – Explanation

Correct: A. Dual reporting is best practice: functional to the board protects independence; administrative to the CEO supports operations.

B wrong: This is the recommended structure, not an impairment.

C wrong: CEO-only reporting impairs independence.

D wrong: Reporting to the external auditor is inappropriate.

Source: Orig Q119

Question: Which statement about the audit committee's approval of the internal audit charter is MOST accurate?

A. The CEO may approve the charter if the board delegates.

B. The external auditor must approve the charter.

C. The charter must be approved by the board (or its audit committee).

D. The charter is approved by the CAE.

Q17 – Explanation

Correct: C. Standard 1000: the charter is approved by the board, often through its audit committee.

A wrong: The board may not delegate charter approval to management.

B wrong: The external auditor has no role in charter approval.

D wrong: The CAE drafts/administers the charter; the board approves it.

Source: Orig Q104

Question: The CAE is asked to lead the implementation of a new enterprise risk management (ERM) framework. Which response BEST preserves conformance with the Standards?

A. Accept only an advisory role, ensuring management retains ownership and decisions.

B. Accept, because ERM is a core internal audit competency.

C. Decline all ERM involvement to protect independence.

D. Accept and later audit the framework as assurance.

Q18 – Explanation

Correct: A. Internal audit may consult on ERM but must not own it or make management decisions; doing so would impair objectivity and preclude later assurance.

B wrong: Competency is not the issue; ownership is. Taking the lead makes internal audit management.

C wrong: Total abstention is overly restrictive; advisory support is permitted.

D wrong: Implementing then auditing the same framework is a self-review threat.

Source: Orig Q101

Question: Which party must approve the removal of the CAE?

A. The CEO acting alone.

B. The CFO.

C. The external auditor.

D. The board.

Q19 – Explanation

Correct: D. Board approval of the CAE's appointment and removal protects the function's independence.

A wrong: A CEO acting alone could remove a CAE who reports on the CEO's own areas.

B wrong: The CFO is part of management.

C wrong: The external auditor has no role in the decision.

Source: New

Question: Which activity is an example of ONGOING monitoring within the quality assurance and improvement program?

A. A comprehensive assessment against the Standards performed every five years by an external team.

B. An annual self-assessment performed by a rotating team of auditors.

C. Supervisory review of workpapers during each engagement together with tracking of performance indicators.

D. A client satisfaction survey sent once at the end of the fiscal year.

Q20 – Explanation

Correct: C. Ongoing monitoring is built into routine management of the function, for example engagement supervision and performance measurement.

A wrong: That describes an external quality assessment.

B wrong: Periodic self-assessments are separate from continuous monitoring.

D wrong: A once-a-year survey is periodic rather than continuous feedback.

Source: New

Question: Which situation MOST clearly indicates that organizational independence is impaired?

A. The CAE attends executive committee meetings as an observer.

B. The board approves the CAE's compensation.

C. The CAE reports administratively to the CEO.

D. The CEO requires that all internal audit reports be reviewed and approved before they are sent to the board.

Q21 – Explanation

Correct: D. Management approval of communications to the board interferes with direct and unrestricted access to the board.

A wrong: Observing executive meetings can improve understanding of the business.

B wrong: Board approval of CAE compensation supports independence.

C wrong: Administrative reporting to the CEO is acceptable alongside functional reporting to the board.

Source: New

Question: Which of the following would satisfy the requirement for an external quality assessment of the internal audit function?

A. A peer review by senior auditors from the organization's own internal audit staff.

B. A review by the organization's compliance function.

C. A self-assessment with independent external validation, performed by a qualified and independent assessor.

D. A review by the CFO's finance team.

Q22 – Explanation

Correct: C. An external assessment may be a full assessment by a qualified independent assessor or team, or a self-assessment with independent validation, performed at least once every five years.

A wrong: Internal audit staff are not independent of the function.

B wrong: Compliance sits inside the organization and is not an independent assessor of internal audit quality.

D wrong: The CFO's team is part of management and lacks independence from the function.

Source: New

Question: What is the PRIMARY benefit of an assurance map?

A. It documents the audit program for each engagement.

B. It shows coverage by the different assurance providers so that gaps and duplication can be identified.

C. It replaces the need for a risk assessment.

D. It measures each auditor's individual performance.

Q23 – Explanation

Correct: B. An assurance map aligns assurance activities across the lines to key risks.

A wrong: Audit programs are engagement-level documents.

C wrong: It builds on a risk assessment and does not replace one.

D wrong: It is not a performance appraisal tool.

Source: New

Question: The board asks the CAE to also lead the compliance function. Which safeguard is MOST necessary?

A. The CAE personally audits compliance and discloses the dual role in the annual report.

B. The board approves the arrangement and assurance over compliance is overseen by a party outside the internal audit function.

C. Compliance is permanently excluded from the audit universe.

D. The CEO approves the arrangement and staff auditors audit compliance.

Q24 – Explanation

Correct: B. When the CAE has responsibilities beyond internal auditing, safeguards are needed. Assurance over those areas must be overseen by an independent party and the board must be informed.

A wrong: Self-review by the CAE is not cured by disclosure.

C wrong: Excluding a risk area leaves an assurance gap and does not resolve the conflict.

D wrong: The board, not the CEO, approves; staff reporting to the CAE would still be reviewing the CAE's own area.

Source: New

Question: An engagement is performed by an external service provider under a co-sourcing agreement. Who retains responsibility for the engagement results and for conformance with the Standards?

A. The CAE.

B. The external service provider.

C. The chair of the audit committee.

D. Management of the area audited.

Q25 – Explanation

Correct: A. The CAE remains responsible for the function's conformance, including work performed by external providers.

B wrong: The provider performs work but cannot take over the CAE's responsibility.

C wrong: The board oversees the function but does not run engagements.

D wrong: Auditee management cannot own conclusions about its own area.

Source: New

Question: What must the CAE do at least annually regarding independence?

A. Obtain the CEO's written assurance that the function is independent.

B. Confirm to the board the organizational independence of the internal audit function.

C. Rotate all internal audit staff to new areas.

D. Obtain an opinion on independence from the external auditor.

Q26 – Explanation

Correct: B. The CAE confirms organizational independence to the board at least annually.

A wrong: Independence is confirmed to the board, not by management assurance.

C wrong: Rotation can be a safeguard but is not the required confirmation.

D wrong: External auditors do not opine on internal audit independence.

Source: New

Question: Under the Global Internal Audit Standards, which domain contains the principles on planning engagements, conducting engagement work, and communicating results?

A. Performing Internal Audit Services.

B. Governing the Internal Audit Function.

C. Managing the Internal Audit Function.

D. Ethics and Professionalism.

Q27 – Explanation

Correct: A. The domain on performing internal audit services covers planning, conducting, and communicating engagements and monitoring action plans.

B wrong: That domain covers board-related governance of the function.

C wrong: That domain covers managing the function: strategy, resources, communication, and quality.

D wrong: That domain covers integrity, objectivity, competency, due professional care, and confidentiality.

Source: New

Question: After a final report has been issued, the CAE discovers a significant error in it. What should the CAE do?

A. Correct the error in the next scheduled report.

B. Communicate corrected information promptly to all parties who received the original report.

C. Inform only the management of the audited area.

D. Take no action if the overall conclusions remain broadly valid.

Q28 – Explanation

Correct: B. Significant errors or omissions discovered after issuance require prompt communication of corrected information to everyone who received the original.

A wrong: Delay leaves users relying on incorrect information.

C wrong: All recipients of the original report must be informed.

D wrong: A significant error requires correction even when overall conclusions stand.

Source: New

Question: In mid-year, the CEO asks internal audit for an unplanned advisory review of a pending acquisition process. What should the CAE do?

A. Accept automatically because the CEO is a key stakeholder.

B. Evaluate the request's risk, value, resource impact, and effect on objectivity; accept if appropriate and communicate significant plan changes to the board.

C. Decline because advisory work must be in the plan approved at the start of the year.

D. Accept and perform it without informing the board, to avoid delay.

Q29 – Explanation

Correct: B. Advisory requests are evaluated against value, risk, resources, and objectivity. Significant changes to the plan are communicated to the board.

A wrong: Requests must be evaluated, not accepted automatically.

C wrong: The plan can be revised; there is no blanket rule against unplanned advisory work.

D wrong: Significant changes to the plan must be communicated.

Source: New

Question: Which activity BEST demonstrates the foresight element of internal audit's purpose?

A. Re-performing last year's controls testing.

B. Following up on whether prior-year findings were closed.

C. Scanning emerging risks and trends and informing the board how they could affect strategic objectives.

D. Counting the number of audit reports issued.

Q30 – Explanation

Correct: C. Foresight means helping the organization anticipate future risks and opportunities.

A wrong: Re-performance is retrospective assurance.

B wrong: Follow-up looks at past issues.

D wrong: Output counts say nothing about forward-looking insight.

Source: New

Question: Which of the following is NOT part of the purpose of internal auditing as described in the Global Internal Audit Standards?

A. Preventing every instance of fraud and error in the organization.

B. Providing independent, risk-based, and objective assurance.

C. Providing advice, insight, and foresight.

D. Strengthening the organization's ability to create, protect, and sustain value.

Q31 – Explanation

Correct: A. Internal auditing provides assurance, advice, insight, and foresight to strengthen value. It cannot guarantee that all fraud and error is prevented.

B wrong: This is part of the stated purpose.

C wrong: This is part of the stated purpose.

D wrong: This is part of the stated purpose.

Source: New

Question: A newly appointed CAE finds that the internal audit charter was last approved six years ago and does not mention advisory services, which the function has been performing. What should the CAE do FIRST?

A. Update the charter and obtain the CEO's signature, since the CEO administers the function.

B. Leave the charter unchanged until the next external quality assessment identifies the gap.

C. Stop all advisory work until the board's next review of the audit plan.

D. Update the charter, discuss it with senior management, and present it to the board for approval.

Q32 – Explanation

Correct: D. The charter defines the mandate, including the scope of assurance and advisory services. The CAE reviews it periodically and the board approves changes after discussion with senior management.

A wrong: The board, not the CEO, approves the charter; a CEO signature does not establish the mandate or independence.

B wrong: Waiting for an assessment delays correcting a known gap that the CAE is responsible for addressing.

C wrong: Halting advisory work is an overreaction; the gap is in documentation of the mandate, which can be fixed promptly.

Source: New

Question: Which practice BEST supports the CAE's independent communication with the board?

A. Giving the board summaries prepared by the CFO.

B. Sending reports to the board only after management's comments are incorporated.

C. Periodic private sessions between the CAE and the board without management present.

D. Meeting the board only when management attends.

Q33 – Explanation

Correct: C. Private sessions allow unfiltered communication.

A wrong: Summaries prepared by the CFO are filtered by management.

B wrong: Management comments belong in reports but should not gate communication to the board.

D wrong: Management's presence can inhibit candor.

Source: New

Question: Which of the following is MANDATORY under the IIA's current professional framework?

A. Global Guidance such as practice guides and supplemental guidance.

B. Examples of evidence of conformance.

C. The Global Internal Audit Standards and applicable Topical Requirements.

D. Considerations for implementation.

Q34 – Explanation

Correct: C. The Standards and Topical Requirements are mandatory. Global Guidance and the implementation and evidence material are recommended.

A wrong: Global Guidance is supplemental and recommended.

B wrong: Examples of evidence are illustrative, not required.

D wrong: Considerations for implementation are recommended practices.

Source: New

Question: Shortly after internal audit issued a critical report on the CEO's discretionary spending, the CEO announces a 40% cut to the internal audit budget. Which action by the CAE is MOST appropriate?

A. Narrow the plan to the lowest-risk areas without raising the matter, since budget is an administrative issue.

B. Shift staff to advisory work, which requires fewer resources.

C. Ask the external auditor to absorb the lost coverage.

D. Communicate to the board how the reduction affects the function's ability to fulfil its mandate and ask the board to resolve the matter.

Q35 – Explanation

Correct: D. The board oversees the adequacy of internal audit resources, and the CAE must report when limitations or possible interference threaten the mandate. A cut following a critical report raises an independence concern.

A wrong: Silently narrowing scope hides a scope limitation from the board.

B wrong: Moving to advisory work neither fixes the resource problem nor addresses the independence concern.

C wrong: The external auditor has a different objective and is not a substitute for the board-approved plan.

Source: New

Question: An auditor completes every step of the standard audit program but noticed several indications of management override of controls. She closes the engagement because the program is complete. Which statement is MOST accurate?

A. She exercised due care because the program was followed.

B. Due care applies only when fraud is confirmed.

C. Due care requires her to continue until all fraud is ruled out.

D. She did not exercise due professional care, because she should have considered whether additional procedures were needed.

Q36 – Explanation

Correct: D. Due professional care requires judgment about the adequacy of procedures given the risks observed, not mechanical completion of a program.

A wrong: Following a program does not by itself demonstrate due care.

B wrong: Due care applies in every engagement.

C wrong: Due care does not require absolute assurance.

Source: New

Question: An auditor worked in procurement 14 months ago and is now assigned to an assurance audit of procurement. Which statement is MOST accurate?

A. The 12-month presumption no longer applies, but the auditor should disclose the prior role so the CAE can assess whether other threats to objectivity exist.

B. The auditor is permanently barred from auditing procurement.

C. No disclosure is needed because more than 12 months have passed.

D. The auditor may proceed only if the procurement manager agrees.

Q37 – Explanation

Correct: A. The presumption of impairment ends after 12 months, but potential impairments must still be disclosed and evaluated.

B wrong: The Standards require evaluation, not a permanent bar.

C wrong: Possible impairments are disclosed regardless of the time elapsed.

D wrong: Auditee management does not decide auditor assignments.

Source: New

Question: Which is the MOST appropriate action if an auditor is asked to audit a process they designed?

A. Decline or request reassignment due to self-review threat.

B. Proceed, since the design was approved.

C. Proceed but use a smaller sample.

D. Proceed and document the design.

Q38 – Explanation

Correct: A. Auditing your own design is a self-review threat; decline or reassign.

B wrong: Approval does not remove the impairment.

C wrong: Smaller samples do not cure self-review.

D wrong: Documentation does not cure the threat.

Source: Orig Q209

Question: The CFO asks the CAE to remove a finding from a draft report because it could affect executive bonuses. The evidence is sound. What should the CAE do?

A. Decline to remove the finding and, if unresolved with the CFO, escalate the matter to the board.

B. Remove the finding but raise it orally with the CFO.

C. Soften the wording until the CFO agrees.

D. Report the finding only to the external auditor.

Q39 – Explanation

Correct: A. Integrity and professional courage require the CAE to report honestly and resist undue influence.

B wrong: Omitting a valid finding misleads report users.

C wrong: Softening to gain agreement distorts a finding the evidence supports.

D wrong: The external auditor does not resolve the internal reporting problem.

Source: New

Question: Last year an auditor advised on the design of new inventory controls. This year she is asked to provide assurance on their operating effectiveness. What is the MOST appropriate action?

A. The CAE evaluates whether the earlier advisory work impairs objectivity and, if necessary, assigns another auditor or applies safeguards.

B. Proceed, because advisory and assurance are separate engagement types.

C. Proceed, as long as she records her prior advice in the workpapers.

D. Require the entire function to stop advisory work.

Q40 – Explanation

Correct: A. Prior advisory involvement can create a self-review threat that must be evaluated before assurance is provided.

B wrong: Different engagement types do not remove a self-review threat.

C wrong: Documentation alone does not remove the impairment.

D wrong: Stopping all advisory work is unnecessary; the issue is managing this specific threat.

Source: New

Question: An auditor is offered a consulting engagement by the CEO to design a new internal control system. Which is the MOST appropriate response?

A. Accept and later audit the system.

B. Decline all consulting.

C. Accept only if the auditor does not assume management responsibility and can maintain objectivity.

D. Accept and manage the implementation.

Q41 – Explanation

Correct: C. Consulting is permitted if objectivity is maintained and management responsibility is avoided.

A wrong: Self-review threat if you audit your own design.

B wrong: Consulting is permitted.

D wrong: Managing implementation is a management role.

Source: Orig Q315

Question: Management gives a plausible explanation for a large unexplained variance that matches last year's explanation. The auditor accepts it without corroboration. Which principle was MOST likely not met?

A. Confidentiality.

B. Professional skepticism.

C. Organizational independence.

D. Technical proficiency in data analytics.

Q42 – Explanation

Correct: B. Professional skepticism means critically assessing evidence and corroborating explanations, particularly for unusual items.

A wrong: The issue is not protection of information.

C wrong: Organizational independence concerns reporting lines.

D wrong: The problem is not a tool or technique gap.

Source: New

Question: An auditor managed the accounts payable process until ten months ago and is now assigned to provide assurance on it. What is the MOST appropriate action?

A. Proceed, since the auditor no longer holds the role.

B. Reassign the engagement, because objectivity is presumed impaired when an auditor assesses an activity for which they were responsible within the previous 12 months.

C. Proceed with a larger sample size.

D. Proceed but exclude the auditor's own prior work from testing.

Q43 – Explanation

Correct: B. The Standards presume impairment when an auditor provides assurance on an activity they were responsible for within the prior 12 months.

A wrong: Leaving the role does not remove the presumption during the 12 months.

C wrong: Sample size does not cure an objectivity impairment.

D wrong: Excluding areas narrows scope and does not remove the bias.

Source: New

Question: An auditor is assigned to audit the payroll function. The auditor's spouse is the payroll supervisor. Which action is MOST appropriate?

A. Proceed, since the spouse does not approve payments.

B. Proceed but avoid interviewing the spouse.

C. Proceed and document the relationship in the workpapers only.

D. Disclose the relationship and request reassignment.

Q44 – Explanation

Correct: D. A close family relationship with the auditee supervisor is an objectivity impairment; the auditor must disclose and be reassigned.

A wrong: The impairment exists regardless of approval authority.

B wrong: Avoiding interviews does not remove the impairment.

C wrong: Documentation alone does not cure an impairment; reassignment is required.

Source: Orig Q102

Question: Which is the MOST likely effect of auditor involvement in designing a control on future assurance?

A. It enhances objectivity.

B. It has no effect.

C. It creates a self-review threat that may preclude later assurance.

D. It guarantees control effectiveness.

Q45 – Explanation

Correct: C. Designing a control creates a self-review threat; later assurance on it may be impaired.

A wrong: It impairs objectivity.

B wrong: It has a significant effect.

D wrong: Design does not guarantee effectiveness.

Source: Orig Q316

Question: Which approach BEST helps the CAE ensure the function collectively has the competencies it needs?

A. Require every auditor to hold the same certification.

B. Periodically assess competencies against engagement needs and plan training, recruitment, and co-sourcing to close gaps.

C. Assign the most complex work to the most senior staff and assume gaps will close.

D. Hire specialists only after a finding is challenged.

Q46 – Explanation

Correct: B. Competency is managed at function level through assessment and a plan to address gaps, with board visibility of significant gaps.

A wrong: Uniform certification does not ensure the mix of skills needed.

C wrong: Senior staff assignment does not address missing skill sets.

D wrong: Reacting after a challenge is too late.

Source: New

Question: The CAE is assigned an engagement on cloud security, but no internal auditor has relevant expertise. Which action is MOST appropriate?

A. Perform it using the cloud vendor's security documentation as primary evidence.

B. Perform it with the best-qualified staff and note the limitation in the report only.

C. Ask the IT department to perform the testing and report results.

D. Obtain the needed competence through training, a co-sourced specialist, or hiring, or decline the engagement and inform the board of the limitation.

Q47 – Explanation

Correct: D. Internal auditors must not perform services for which they lack the needed competencies; they obtain competent assistance or decline.

A wrong: Vendor documentation is not sufficient evidence and does not close the competence gap.

B wrong: Disclosure alone does not supply competence.

C wrong: IT testing its own security lacks independence.

Source: New

Question: Which compensation arrangement for the CAE would MOST threaten objectivity?

A. A bonus tied to the board's assessment of the quality of the function.

B. A fixed salary set annually by the board.

C. A bonus tied to completion of the approved audit plan.

D. A bonus tied to the organization's reported net income.

Q48 – Explanation

Correct: D. Pay tied to the results of the areas being audited creates a self-interest threat to the CAE's objectivity.

A wrong: Board-assessed quality is aligned with the function's mandate.

B wrong: A board-set fixed salary supports independence.

C wrong: Plan completion is an activity measure, not a stake in auditees' results.

Source: New

Question: An auditor uses a generative AI tool to draft a finding. The draft cites a control test that was never performed, and the auditor includes it in the report. Who is accountable?

A. The AI vendor.

B. The auditor and, ultimately, the CAE, because auditors must validate AI outputs before relying on them.

C. The auditee, who should have noticed the error.

D. No one, since the error was unintentional.

Q49 – Explanation

Correct: B. Internal auditors remain responsible for the accuracy of their work and must validate tool outputs before using them.

A wrong: Tool providers do not take on professional accountability.

C wrong: The auditee is not responsible for the accuracy of audit work.

D wrong: Lack of intent does not remove professional accountability.

Source: New

Question: Midway through fieldwork, an auditor learns that her brother-in-law is a major supplier of the auditee. What should she do FIRST?

A. Continue and mention the relationship in the final report.

B. Withdraw from the engagement without telling anyone.

C. Ask the auditee to stop using that supplier.

D. Disclose the relationship to the CAE so that safeguards or reassignment can be decided.

Q50 – Explanation

Correct: D. Possible impairments are disclosed promptly to the appropriate party so the CAE can decide how to respond.

A wrong: Disclosure should be prompt, not deferred to the report.

B wrong: Silent withdrawal leaves questions about work already done.

C wrong: Asking the auditee to act is inappropriate influence.

Source: New

Question: Which situation is the clearest example of a SELF-INTEREST threat to objectivity?

A. An auditor has audited the same department for six consecutive years.

B. An auditor's annual bonus depends on the financial results of the unit she is auditing.

C. An auditee manager asks an auditor to change a finding.

D. An auditor reviews a process she designed last year.

Q51 – Explanation

Correct: B. A personal financial stake in the audited area creates a self-interest threat.

A wrong: That is a familiarity threat.

C wrong: That is undue influence or intimidation.

D wrong: That is a self-review threat.

Source: New

Question: An internal auditor wants to paste confidential interview notes into a public generative AI tool to produce a summary. What is the BEST response?

A. Use it, because interview notes contain no financial data.

B. Use it after removing names only.

C. Do not use the tool for confidential data until confidentiality and accuracy risks are assessed and the tool is approved under organizational policy.

D. Use it, because the vendor's marketing says data is private.

Q52 – Explanation

Correct: C. Confidentiality requires protecting information. Technology use should follow policy and a risk assessment.

A wrong: Interview notes can contain sensitive information.

B wrong: Removing names does not address other sensitive content or the tool's data handling.

D wrong: Marketing claims are not a risk assessment.

Source: New

Question: An auditor wants to work evenings as a paid consultant for a vendor of the organization. What should she do?

A. Proceed because it is outside working hours.

B. Proceed if she does not audit that vendor's contracts.

C. Disclose the proposed activity to the CAE so that the potential conflict can be evaluated.

D. Proceed only if the vendor agrees to keep it confidential.

Q53 – Explanation

Correct: C. Outside activities that could impair objectivity or create conflicts must be disclosed so they can be evaluated.

A wrong: Working hours do not determine whether a conflict exists.

B wrong: The auditor cannot decide the conflict question on her own.

D wrong: The vendor cannot clear a conflict on the auditor's behalf.

Source: New

Question: An auditor discovers a colleague has falsified a workpaper. Which is the MOST appropriate action?

A. Report the matter through appropriate channels (e.g., CAE/ethics hotline).

B. Ignore it.

C. Confront the colleague privately and drop it.

D. Alter the workpaper yourself.

Q54 – Explanation

Correct: A. Falsified workpapers are an integrity issue; report through proper channels.

B wrong: Ignoring misconduct is a violation.

C wrong: Private resolution may hide misconduct.

D wrong: Altering evidence is itself misconduct.

Source: Orig Q311

Question: A regulator serves a subpoena for internal audit workpapers from a closed engagement. What should the CAE do?

A. Refuse to release anything on confidentiality grounds.

B. Release the entire workpaper file immediately.

C. Consult legal counsel and senior management and release only what is legally required.

D. Let the auditee decide what is released.

Q55 – Explanation

Correct: C. Confidentiality is not absolute where the law compels disclosure, but disclosure should be controlled and limited to what is required.

A wrong: Refusing could breach a legal obligation.

B wrong: Releasing everything exceeds what is required.

D wrong: The auditee has a conflict of interest.

Source: New

Question: Which of the following is a CORRECTIVE control?

A. Batch totals that reject unbalanced entries.

B. Restoring corrupted data from backups and revising procedures after an incident.

C. Complexity requirements for passwords.

D. Daily review of an exception report.

Q56 – Explanation

Correct: B. Corrective controls remedy the effects of an event after it has occurred.

A wrong: Rejecting unbalanced entries prevents errors.

C wrong: Password rules are preventive.

D wrong: Reviewing exceptions is detective.

Source: New

Question: Which is the MOST likely risk of using a "black box" data analytics tool?

A. The auditor cannot explain or validate the logic behind the results.

B. The tool is too fast.

C. The tool produces too much documentation.

D. The tool is too cheap.

Q57 – Explanation

Correct: A. If the logic is opaque, the auditor cannot validate or explain the results.

B wrong: Speed is not a risk.

C wrong: Documentation is not a risk.

D wrong: Cost is not a risk.

Source: Orig Q305

Question: Inherent exposure is estimated at a 50% annual probability of a $2 million loss. A control lowers the probability to 20% and costs $150,000 per year. What is the net annual benefit of the control, ignoring other factors?

A. $450,000.

B. $600,000.

C. $750,000.

D. $250,000.

Q58 – Explanation

Correct: A. Expected loss falls from $1,000,000 to $400,000, a $600,000 reduction. Less the $150,000 cost, the net benefit is $450,000.

B wrong: That is the gross reduction before subtracting cost.

C wrong: That adds the cost instead of subtracting it.

D wrong: That subtracts the cost from the residual expected loss rather than from the risk reduction.

Source: New

Question: An auditor uses a data analytics script that filters transactions above a threshold. Which is the MOST likely risk?

A. The script is too fast.

B. The threshold may exclude relevant transactions (incompleteness).

C. The script produces too much documentation.

D. The script is too cheap.

Q59 – Explanation

Correct: B. Filtering risks excluding relevant transactions, creating incompleteness.

A wrong: Speed is not a risk.

C wrong: Documentation is not a risk.

D wrong: Cost is not a risk.

Source: Orig Q326

Question: Under COSO's Internal Control - Integrated Framework (2013), the principle that the organization specifies objectives with sufficient clarity to identify and assess related risks belongs to which component?

A. Control Environment.

B. Control Activities.

C. Risk Assessment.

D. Monitoring Activities.

Q60 – Explanation

Correct: C. Objective setting with sufficient clarity underpins risk identification and assessment.

A wrong: The control environment covers integrity, oversight, structure, competence, and accountability.

B wrong: Control activities are the actions that mitigate risks.

D wrong: Monitoring evaluates whether controls are present and functioning.

Source: New

Question: The organization's risk management is immature and the risk register is outdated. How should the CAE develop the internal audit plan?

A. Use the outdated register because it is management's official view.

B. Perform internal audit's own risk assessment with input from management and the board and communicate the limitation to the board.

C. Defer plan development until risk management matures.

D. Ask management to prepare the plan.

Q61 – Explanation

Correct: B. The plan must be risk-based; where management's process is weak, internal audit uses its own assessment and informs the board.

A wrong: An outdated register would give a misleading basis for the plan.

C wrong: The plan cannot wait for management's maturity.

D wrong: Planning is the CAE's responsibility.

Source: New

Question: Which IT finding is MOST significant?

A. A shared administrator account used by developers in the production database with no activity logging.

B. Three low-privilege accounts have passwords older than policy allows.

C. Quarterly access review sign-offs were dated a few days late.

D. Change tickets use an outdated template.

Q62 – Explanation

Correct: A. Shared privileged access with no logging breaks accountability and lets changes to production data go undetected.

B wrong: Low-privilege accounts pose limited exposure.

C wrong: Minor timing delays have limited impact.

D wrong: A template issue is documentation-related.

Source: New

Question: Which is NOT one of the five components of the COSO Enterprise Risk Management framework (2017)?

A. Governance and Culture.

B. Control Activities.

C. Performance.

D. Review and Revision.

Q63 – Explanation

Correct: B. The ERM framework's components are Governance and Culture; Strategy and Objective-Setting; Performance; Review and Revision; and Information, Communication, and Reporting. Control Activities is a component of the Internal Control framework.

A wrong: This is an ERM component.

C wrong: This is an ERM component.

D wrong: This is an ERM component.

Source: New

Question: An auditor is reviewing a cloud service provider's SOC 2 Type II report. Which is the MOST important consideration?

A. The report guarantees the provider is secure.

B. The report replaces the need for any internal audit testing.

C. The report is only relevant to external audit.

D. The report covers a period, so the auditor must assess whether the period is recent enough and whether complementary user entity controls (CUECs) are implemented.

Q64 – Explanation

Correct: D. A SOC 2 Type II covers a period; the auditor must evaluate the period's relevance and confirm the client implemented the CUECs.

A wrong: No report guarantees security.

B wrong: SOC reports inform, but do not eliminate, internal audit testing.

C wrong: SOC reports are relevant to internal audit too.

Source: Orig Q301

Question: A business impact analysis sets a four-hour RTO and a one-hour RPO for the order-processing system. The system is backed up nightly with no replication. What is the MOST significant gap?

A. A four-hour RTO is too short for any system.

B. Nightly backups make the RTO impossible to meet.

C. Recovery objectives should not be set in a BIA.

D. Nightly backups could lose up to a day of data, which exceeds the one-hour RPO.

Q65 – Explanation

Correct: D. RPO is the maximum tolerable data loss. Nightly backups without replication can lose up to about 24 hours.

A wrong: RTO values are a business decision and can be achievable.

B wrong: Backup frequency relates to RPO; RTO depends on recovery speed.

C wrong: Setting recovery objectives is a core output of a BIA.

Source: New

Question: Management relies on an automated three-way match. Internal audit has concluded that IT general controls over access and change management were effective all year. Which approach to testing the application control is MOST efficient and appropriate?

A. Test a large statistical sample across the year as for a manual control.

B. Rely on management's description without testing.

C. Test the control logic once, for example by inspecting configuration or testing a few transactions, and rely on effective ITGCs for the period.

D. Test only the vendor's user documentation.

Q66 – Explanation

Correct: C. Automated controls operate consistently unless changed, so with effective ITGCs a limited test can support reliance.

A wrong: That approach is unnecessary for a stable automated control.

B wrong: Management's description is not evidence the control works.

D wrong: Documentation does not demonstrate how the control operates.

Source: New

Question: An auditor uses data analytics to test 100% of a transaction population. Which is the MOST likely benefit?

A. Eliminates the need for professional judgment.

B. Enables full-population testing and identifies anomalies that sampling might miss.

C. Replaces the audit report.

D. Guarantees no fraud.

Q67 – Explanation

Correct: B. Full-population analytics can identify anomalies and patterns that sampling may miss.

A wrong: Judgment is always required.

C wrong: Analytics does not replace the report.

D wrong: No method guarantees no fraud.

Source: Orig Q303

Question: A SOC 2 report states that the cloud provider's hosting subservice organization is carved out. What does this mean for the user's assessment?

A. Controls at the subservice organization are not covered by the opinion, so the user must obtain separate assurance or otherwise monitor them.

B. The subservice organization's controls are included and tested in the report.

C. The service organization has no responsibility for services provided by the subservice organization.

D. The report cannot be used for any purpose.

Q68 – Explanation

Correct: A. Under the carve-out method, subservice organization controls are excluded from the description and opinion.

B wrong: That describes the inclusive method.

C wrong: The service organization generally remains accountable to its customers; the report just excludes those controls.

D wrong: The report remains useful for the controls it does cover.

Source: New

Question: Which control is MOST effective for a critical spreadsheet used in the financial close?

A. A single password shared by all team members.

B. Version control, restricted access, locked formulas, and independent review and testing of logic changes.

C. A footer stating the file is for management use only.

D. An annual reminder to be careful with spreadsheets.

Q69 – Explanation

Correct: B. End-user computing risk is addressed through access, change control, input and logic protection, and independent review.

A wrong: Shared passwords destroy accountability.

C wrong: A footer is not a control.

D wrong: Reminders do not prevent or detect errors.

Source: New

Question: Management buys cyber insurance to respond to the risk of a data breach. Which statement is MOST accurate?

A. It is risk avoidance, so the risk no longer exists.

B. It is risk acceptance, since the insurer bears all loss.

C. It is a risk-sharing response; residual exposure such as reputational damage and regulatory consequences remains with the organization.

D. It eliminates the need for preventive controls.

Q70 – Explanation

Correct: C. Insurance shares part of the financial loss, but accountability and some consequences cannot be transferred.

A wrong: Avoidance means exiting the activity that creates the risk.

B wrong: Insurance is a sharing response, and it does not cover every consequence.

D wrong: Controls are still needed to reduce likelihood and impact and may be required by the insurer.

Source: New

Question: The auditor identifies a deficiency that could result in a material misstatement but management has a compensating control. The auditor should:

A. Ignore the deficiency.

B. Immediately classify it as a material weakness.

C. Remove the finding.

D. Assess whether the compensating control mitigates the risk.

Q71 – Explanation

Correct: D. Evaluate whether a compensating control reduces the risk before classifying severity.

A wrong: Deficiencies must be assessed.

B wrong: Classification depends on mitigation.

C wrong: The finding must be documented.

Source: Orig Q129

Question: A payroll service provider gives the company a SOC 1 Type 1 report. The auditor wants assurance that the provider's controls operated effectively throughout the year. What is the MOST appropriate conclusion?

A. A Type 1 report is sufficient because it covers all controls over the year.

B. A Type 1 report covers design at a point in time; obtain a Type 2 report or perform other procedures to assess operating effectiveness.

C. A Type 1 report is equivalent to a Type 2 report for management's use.

D. Operating effectiveness is irrelevant for outsourced processes.

Q72 – Explanation

Correct: B. Type 1 reports address design as of a date. Type 2 reports test operating effectiveness over a period.

A wrong: Type 1 does not cover a period.

C wrong: The two report types provide different levels of evidence.

D wrong: Responsibility for outsourced controls remains with the user organization.

Source: New

Question: A company runs virtual machines on an infrastructure-as-a-service (IaaS) cloud. Under the shared responsibility model, who is normally responsible for patching the guest operating systems?

A. The cloud provider.

B. The regulator.

C. The customer.

D. The hardware vendor.

Q73 – Explanation

Correct: C. In IaaS, the provider secures the underlying infrastructure while the customer manages the operating systems, applications, and data.

A wrong: The provider handles the physical and virtualization layers.

B wrong: Regulators do not perform patching.

D wrong: Hardware vendors are not responsible for guest operating systems.

Source: New

Question: Who should be primarily responsible for periodically reviewing whether users' access rights to a financial application remain appropriate?

A. The IT help desk.

B. The business owners of the application and its data.

C. Internal audit as part of its operating role.

D. The software vendor.

Q74 – Explanation

Correct: B. Access recertification is a management control; business owners understand who needs access to perform their duties.

A wrong: The help desk administers access but does not decide appropriateness.

C wrong: Internal audit tests the control; performing it would impair independence.

D wrong: The vendor does not know the organization's roles.

Source: New

Question: Which statement about risk appetite and risk tolerance is MOST accurate?

A. Tolerance is the acceptable variation in performance relative to specific objectives and is more specific than appetite.

B. Appetite is the acceptable variation around objectives; tolerance is the broad level of risk accepted to create value.

C. Both terms refer to the amount of risk the internal auditor accepts.

D. Risk capacity is always lower than risk appetite.

Q75 – Explanation

Correct: A. Appetite is the broad type and amount of risk an organization is willing to pursue. Tolerance sets acceptable variation around specific objectives.

B wrong: That reverses the two definitions.

C wrong: Appetite and tolerance relate to the organization, not the auditor.

D wrong: Capacity, the maximum risk the organization can bear, is above appetite.

Source: New

Question: An organization uses a vendor's machine-learning model to approve loans. Which assurance focus is MOST important for internal audit?

A. Whether the model is validated and monitored for performance and bias, outputs are explainable, and accountable owners and human oversight are defined.

B. Whether the vendor's marketing claims high accuracy.

C. Whether the model code is stored on company servers.

D. Whether the model reduces headcount.

Q76 – Explanation

Correct: A. Governance of AI models centers on validation, monitoring, bias, explainability, accountability, and human oversight.

B wrong: Marketing claims are not evidence of performance.

C wrong: Where code is stored does not address decision quality or fairness.

D wrong: Headcount savings are not an assurance objective.

Source: New

Question: A small company's bookkeeper records receipts and prepares the bank reconciliation. Which is the BEST compensating control?

A. The bookkeeper reviews her own reconciliation for a second time.

B. The company requires annual ethics training.

C. The auditor performs a walkthrough once a year.

D. The owner independently reviews bank statements and the reconciliation and investigates reconciling items.

Q77 – Explanation

Correct: D. Independent review by someone not involved in recording provides a check where duties cannot be segregated.

A wrong: Self-review does not provide independence.

B wrong: Training does not detect misstatements or misappropriation.

C wrong: An annual walkthrough is not a recurring control.

Source: New

Question: Who is responsible for deciding to accept residual risk that exceeds the organization's stated risk appetite?

A. Management, with the board involved when the risk exceeds appetite or delegated authority; internal audit does not make the decision.

B. The CAE, because internal audit identified the risk.

C. The external auditor, as part of the audit opinion.

D. The compliance officer alone.

Q78 – Explanation

Correct: A. Risk acceptance decisions are management and governing body decisions. Internal audit's role is to communicate concerns.

B wrong: The CAE would be assuming a management responsibility.

C wrong: External auditors do not decide risk acceptance.

D wrong: Compliance may advise but does not own the decision alone.

Source: New

Question: Which segregation-of-duties conflict in IT creates the HIGHEST risk of unauthorized or untested changes to production systems?

A. A help-desk analyst who logs and closes password-reset tickets.

B. A database administrator who attends vendor management meetings.

C. A developer who can also move code into the production environment.

D. A security analyst who prepares user-awareness training material.

Q79 – Explanation

Correct: C. Developer and production-migration duties should be separated so that changes are independently authorized and tested.

A wrong: That is a low-risk administrative overlap.

B wrong: Attending meetings does not give control over production changes.

D wrong: Training material does not affect production systems.

Source: New

Question: Which control BEST reduces the IMPACT, rather than the likelihood, of a ransomware attack?

A. Phishing awareness training.

B. Multi-factor authentication for remote access.

C. Timely patching of internet-facing servers.

D. Immutable, offline backups with regularly tested restoration.

Q80 – Explanation

Correct: D. Tested offline or immutable backups allow recovery without paying, limiting damage after an attack.

A wrong: Training reduces the likelihood of initial compromise.

B wrong: MFA reduces the likelihood of unauthorized access.

C wrong: Patching reduces the likelihood of exploitation.

Source: New

Question: Which function did the NIST Cybersecurity Framework 2.0 add to the original five functions?

A. Identify.
B. Respond.
C. Recover.
D. Govern.

Q81 – Explanation

Correct: D. CSF 2.0 added Govern to Identify, Protect, Detect, Respond, and Recover.

A wrong: Identify was in the original framework.

B wrong: Respond was in the original framework.

C wrong: Recover was in the original framework.

Source: New

Question: Which of the following is NOT an IT general control domain?

A. Logical access to programs and data.

B. Program change management.

C. Computer operations, including backup and job scheduling.

D. Edit checks that reject invalid dates entered in the payroll application.

Q82 – Explanation

Correct: D. Edit checks within an application are application controls. ITGCs support the environment in which applications run.

A wrong: Access is a core ITGC domain.

B wrong: Change management is a core ITGC domain.

C wrong: Operations is a core ITGC domain.

Source: New

Question: Which approach would BEST enable internal audit to assess the organization's ethical culture?

A. Confirm that a code of conduct exists and is posted online.

B. Count the number of hotline reports received.

C. Interview only the chief ethics officer.

D. Evaluate ethics-related objectives, programs, and activities, including tone at the top, hotline use, training, investigations, and consistent discipline.

Q83 – Explanation

Correct: D. Culture assessment looks at whether ethical expectations are communicated, practiced, and enforced.

A wrong: Existence of a code does not show it is followed.

B wrong: Report counts alone are ambiguous; low counts may mean mistrust.

C wrong: A single interview gives a narrow and potentially biased view.

Source: New

Question: Which is the BEST way to test the reliability of a data analytics result?

A. Trust the tool blindly.

B. Validate completeness and accuracy of the source data and reconcile to the general ledger.

C. Rely on management's statement.

D. Skip validation if the tool is expensive.

Q84 – Explanation

Correct: B. Validate the completeness and accuracy of source data and reconcile to the GL.

A wrong: Blind trust is improper.

C wrong: Management's statement is not validation.

D wrong: Cost does not replace validation.

Source: Orig Q304

Question: Management plans to let an autonomous AI agent execute vendor payments up to $50,000 without human review. Which control is MOST important to require before approval?

A. Annual user-awareness training on AI.

B. A vendor SLA guaranteeing uptime.

C. A prompt library maintained by the project team.

D. Defined authority limits with least-privilege access, human approval above thresholds, complete logging of actions, and a named accountable owner.

Q85 – Explanation

Correct: D. Autonomous actions with financial impact require bounded authority, oversight, traceability, and accountability.

A wrong: Training does not constrain what the agent can do.

B wrong: Uptime does not address authorization or errors.

C wrong: A prompt library does not provide control over the agent's actions.

Source: New

Question: Which condition MOST likely indicates collusion?

A. A well-documented approval trail.

B. Two employees sharing a password and rotating duties.

C. A single vendor with low prices.

D. A monthly reconciliation.

Q86 – Explanation

Correct: B. Shared passwords and rotating duties can defeat segregation of duties and indicate collusion.

A wrong: A good approval trail is a positive control indicator.

C wrong: A single low-cost vendor is not itself a red flag.

D wrong: Reconciliations are detective controls.

Source: Orig Q107

Question: Which is the MOST appropriate action if the auditor discovers the auditee has destroyed evidence?

A. Reconstruct the evidence yourself.

B. Document the destruction and notify appropriate authorities (e.g., legal/board).

C. Ignore it.

D. Confront the auditee aggressively.

Q87 – Explanation

Correct: B. Document the fact and escalate per policy; evidence destruction may be illegal.

A wrong: Reconstruction may be impossible or inappropriate.

C wrong: Ignoring spoliation is improper.

D wrong: Aggressive confrontation may escalate risk.

Source: Orig Q155

Question: Which is the MOST appropriate role for internal audit in fraud?

A. Lead the investigation and interrogate suspects.

B. Decide guilt and impose discipline.

C. Approve management's fraud policy.

D. Assess fraud risk and evaluate controls.

Q88 – Explanation

Correct: D. Internal audit assesses fraud risk and evaluates controls; management and legal lead investigations and decisions.

A wrong: Interrogation and leading investigations are management/legal roles.

B wrong: Discipline is a management/HR decision.

C wrong: The board approves the fraud policy.

Source: Orig Q108

Question: Which is the MOST likely indicator of a fraudulent financial reporting scheme?

A. Revenue growth consistent with cash flow.

B. Strong controls.

C. Revenue growth far exceeding cash flow.

D. Timely reporting.

Q89 – Explanation

Correct: C. Revenue outpacing cash flow may indicate fictitious or premature revenue recognition.

A wrong: Consistency is a positive sign.

B wrong: Strong controls reduce risk.

D wrong: Timely reporting is positive.

Source: Orig Q211

Question: A company ships excess inventory to distributors at quarter-end under a side agreement allowing free return, and recognizes revenue on shipment. Which scheme is this?

A. Lapping.

B. Skimming.

C. Channel stuffing.

D. Payroll fraud.

Q90 – Explanation

Correct: C. Channel stuffing inflates reported sales through shipments that are likely to be returned.

A wrong: Lapping conceals theft of receipts.

B wrong: Skimming takes cash before it is recorded.

D wrong: No payroll element is involved.

Source: New

Question: A cashier steals a payment from Customer A, then later credits Customer A's account using a payment received from Customer B, and continues this pattern to avoid detection. Which scheme is this?

A. Check kiting.

B. Channel stuffing.

C. Lapping.

D. Round-tripping.

Q91 – Explanation

Correct: C. Lapping conceals theft of receipts by applying later receipts to earlier accounts.

A wrong: Kiting exploits float between bank accounts.

B wrong: Channel stuffing inflates sales by overshipping to distributors.

D wrong: Round-tripping involves offsetting transactions that inflate revenue.

Source: New

Question: An employee who has never taken a vacation in six years handles all vendor setups and payments. Which control BEST addresses the risk that an ongoing scheme remains hidden?

A. An annual ethics acknowledgment.

B. Higher password complexity.

C. Mandatory vacations and job rotation.

D. A more detailed job description.

Q92 – Explanation

Correct: C. Absence and rotation force others to perform the duties and expose irregularities.

A wrong: Acknowledgments do not expose a scheme.

B wrong: Passwords do not address concealment through continuous control of the process.

D wrong: A job description does not reveal ongoing manipulation.

Source: New

Question: Which scheme falls into the corruption category of occupational fraud?

A. A purchasing manager receives kickbacks from a supplier in return for awarding contracts.

B. A clerk takes cash received before it is recorded.

C. A payroll clerk adds a fictitious employee.

D. A warehouse worker steals inventory.

Q93 – Explanation

Correct: A. Corruption involves misuse of influence in a business transaction for personal gain, such as kickbacks.

B wrong: That is skimming, an asset misappropriation.

C wrong: That is a payroll scheme, an asset misappropriation.

D wrong: That is inventory theft, an asset misappropriation.

Source: New

Question: Which procedure is MOST likely to detect ghost employees on the payroll?

A. Recompute gross pay for a sample of employees.

B. Compare total payroll expense with budget.

C. Verify that withholding tax rates were applied correctly.

D. Match payroll records (bank accounts, addresses, tax IDs) to HR and other employee master data and verify the existence of selected employees.

Q94 – Explanation

Correct: D. Ghost employees do not exist or do not work, so tests must confirm existence and look for anomalies in master data.

A wrong: Recomputation tests accuracy for people already on the register.

B wrong: Budget comparison is too aggregated.

C wrong: Tax rate checks test accuracy, not existence.

Source: New

Question: Which analytical test uses the expected frequency of leading digits to identify potentially fabricated numbers?

A. Regression analysis of revenue against cash.

B. Ratio analysis of gross margin.

C. Stratification of invoices by size.

D. Benford's law analysis.

Q95 – Explanation

Correct: D. Benford's law compares observed leading-digit frequencies to the expected distribution to flag unusual patterns.

A wrong: Regression examines relationships between variables.

B wrong: Ratio analysis compares financial relationships.

C wrong: Stratification groups items by size and does not test digit frequency.

Source: New

Question: Which is the MOST likely indicator of procurement fraud in a public entity?

A. Split purchases to avoid approval thresholds.
B. Competitive bidding.
C. Timely payments.
D. Documented approvals.

Q96 – Explanation

Correct: A. Splitting purchases to avoid approval thresholds is a classic fraud red flag.

B wrong: Competitive bidding is a control.

C wrong: Timely payment is positive.

D wrong: Documented approvals are positive.

Source: Orig Q324

Question: What element does the fraud diamond add to the fraud triangle?

A. Detection probability.

B. Capability: the individual's position, skills, and ability to carry out and conceal the fraud.

C. Materiality.

D. Concealment cost.

Q97 – Explanation

Correct: B. The fraud diamond adds capability to pressure, opportunity, and rationalization.

A wrong: Detection probability is not a diamond element.

C wrong: Materiality is an assessment concept, not a fraud element.

D wrong: Concealment cost is not a diamond element.

Source: New

Question: During a fraud investigation, which action BEST preserves the admissibility of evidence?

A. Interview the suspect before securing records.

B. Copy files to a personal drive for easier review.

C. Secure original documents and electronic records, maintain a chain of custody, and restrict access.

D. Notify all staff so they preserve relevant records.

Q98 – Explanation

Correct: C. A documented chain of custody and limited access protect evidence integrity.

A wrong: Alerting the suspect first risks evidence loss.

B wrong: Personal storage breaks custody and control.

D wrong: A broad announcement can tip off the suspect and spread information beyond need-to-know.

Source: New

Question: Invoices from a vendor with only a PO box address and no telephone number, in amounts just below the approval threshold, are all approved by one buyer. Which scheme is MOST likely?

A. Payroll skimming.

B. A shell-company billing scheme.

C. Overstated expense reimbursements.

D. Cash larceny from a register.

Q99 – Explanation

Correct: B. A fictitious vendor, an untraceable address, and amounts structured under approval limits are classic indicators of a shell-company billing scheme.

A wrong: Nothing in the facts relates to payroll.

C wrong: The facts involve a vendor, not an employee's expense claims.

D wrong: Cash larceny involves taking cash on hand.

Source: New

Question: An anonymous hotline tip alleges that the CEO falsified expense reports. What should the CAE do FIRST?

A. Inform the CEO and ask for an explanation.

B. Assess the credibility of the allegation and follow the board-approved protocol, informing the audit committee chair because senior management is implicated.

C. Confront the CEO with the allegation.

D. Dismiss it because it is anonymous.

Q100 – Explanation

Correct: B. When senior management is implicated, the allegation goes to the board or audit committee, through the established protocol, not to the person alleged.

A wrong: Alerting the CEO risks evidence destruction and compromises independence.

C wrong: Confronting the subject first is inappropriate.

D wrong: Anonymous tips must still be assessed.

Source: New

Answer key

1:A 2:D 3:D 4:A 5:C 6:A 7:B 8:C 9:A 10:C 11:C 12:D 13:D 14:A 15:A 16:A
17:C 18:A 19:D 20:C 21:D 22:C 23:B 24:B 25:A

26:B 27:A 28:B 29:B 30:C 31:A 32:D 33:C 34:C 35:D 36:D 37:A 38:A 39:A
40:A 41:C 42:B 43:B 44:D 45:C 46:B 47:D 48:D 49:B 50:D

51:B 52:C 53:C 54:A 55:C 56:B 57:A 58:A 59:B 60:C 61:B 62:A 63:B 64:D
65:D 66:C 67:B 68:A 69:B 70:C 71:D 72:B 73:C 74:B 75:A

76:A 77:D 78:A 79:C 80:D 81:D 82:D 83:D 84:B 85:D 86:B 87:B 88:D 89:C
90:C 91:C 92:C 93:A 94:D 95:D 96:A 97:B 98:C 99:B 100:B